

内部使用

Windows 应用程序安全测试报告 — 全工具链 路验证

target.exe

报告编号	WS-20261006-014
被测程序	target.exe
程序版本	10.0.26100.9278 (WinBuild.160101.0800)
SHA-256	468ffe129c395abf6b21a09efdf261910a95fb98aa982ead73caa7b2b684577e
分析员	TianManyi
生成时间	2026-10-06 10:27:27
分析主机	WIN-O58D1FE3C92 / Microsoft Windows NT 10.0.26200.0
风险结论	存在中风险问题，建议按迭代修复

目录

- | | |
|---------|--------|
| 1 执行摘要 | 6 依赖分析 |
| 2 程序信息 | 7 安全发现 |
| 3 测试环境 | 8 证据链 |
| 4 静态分析 | 9 风险整改 |
| 5 运行期观测 | 10 附录 |

1. 执行摘要



总体结论：存在中风险问题，建议按迭代修复

本次测试未发现严重或高危问题，但存在若干中风险项。建议纳入技术债跟踪，在后续版本中逐步收敛。

本次测试覆盖情况：静态分析：已完成；动态分析：未执行；网络采集：无记录；权限：标准用户；证据条数：23。

需立即关注

编号	等级	问题	建议动作
WS-101	中危	可执行文件缺少有效的数字签名	为发布版本配置代码签名证书（EV 证书可获得 SmartScreen 立即信誉），在 CI 中对每个产物签名并校验。

发现项清单

编号	等级	标题	置信度	类别
WS-101	中危	可执行文件缺少有效的数字签名	高	代码完整性与签名
WS-102	信息	二进制保留了调试信息（PDB 路径）	高	防篡改与构建可信性
WS-103	信息	测试环境权限不足，部分证据的完整性受限	高	工具链与环境

采集覆盖一览

维度	覆盖情况
静态分析	已完成（PE 结构 / 字符串 / 依赖 / 签名）
类型识别	已完成（C / C++ 原生应用）
动态分析	未执行
网络采集	未采集
权限级别	标准用户（部分证据精度受限）
证据条数	23

2. 程序信息

文件名	target.exe
完整路径	C:\Users\TianManyi\WorkBuddy\winseclab\wsx-smoke\Projects\WS-20261006-014_全工具链路验证\Target\target.exe
文件大小	360,448 字节 (0.34 MB)
SHA-256	468ffe129c395abf6b21a09efdf261910a95fb98aa982ead73caa7b2b684577e
MD5	8a1d8175ccca97054cdb25acbb4cc07e
IMPHASH	728a1b3f7dd708a087950594ffdf6c20
文件版本	10.0.26100.9278 (WinBuild.160101.0800)
产品名称	Microsoft® Windows® Operating System
公司	Microsoft Corporation
文件说明	Notepad
签名状态	未签名
签名者	—
签名时间戳	无
识别类型	C / C++ 原生应用
识别置信度	98%

类型识别依据

信号	说明	权重
原生映像	无托管 / 框架运行时特征, 节区 .text fothk .rdata .data .pdata .didat	3

3. 测试环境

主机名	WIN-O58D1FE3C92
测试账号	TianManyi
操作系统	Microsoft Windows NT 10.0.26200.0 (Build 10.0.26200.0)
系统架构	X64
.NET 运行时	.NET 10.0.5
管理员权限	否（部分证据精度受限）
虚拟化环境	未检测到虚拟化特征
处理器 / 内存	16 逻辑核心 / 31.3 GB
分析器版本	WinSecLab 0.1.0
环境快照时间	2026-10-06 09:53:38
会话 ID	—

未检测到虚拟化环境。按 §14 沙箱设计要求，未知或高风险程序应在 Hyper-V / Windows Sandbox 等隔离环境中运行。

4. 静态分析

PE 有效性	有效
架构 / 子系统	x64 / WindowsGui
CLR 映像类型	PE32Plus
编译器	MSVC 14.x (Visual Studio 2015 – 2026) — 构建号指向 Visual Studio 2022 17.8+ (链接器 14.38)
编译依据	Rich Header 构建号 33145 (MSVC 14.x (Visual Studio 2015 – 2026) — 构建号指向 Visual Studio 2022 17.8+)
时间戳	1979-02-20 02:32:04 (可复现构建伪时间戳)
入口点 RVA	0x19C0
镜像基址	0x140000000
节区数	8
导入	56 个模块 / 315 个函数
延迟导入	6 项
导出	0
资源条目	31
整体熵值	6.4825 (偏高)
Overlay	无
缓解措施	ASLR DEP TSAAware HighEntropyVA CFG
Rich Header	共 10 条编译单元记录, 最高构建号 33145
PDB 路径	notepad.pdb

节区明细

节区	权限	虚拟大小	原始大小	熵值	性质
.text	R-X	157,666	159,744	6.2382	偏高
fothk	R-X	4,096	4,096	0.0159	极低 (大量零填充)
.rdata	R--	42,696	45,056	5.5819	偏高
.data	RW-	10,048	4,096	1.6243	偏低 (结构化数据)
.pdata	R--	4,632	8,192	3.3201	偏低 (结构化数据)

节区	权限	虚拟大小	原始大小	熵值	性质
.didat	RW-	248	4,096	0.2520	极低（大量零填充）
.rsrc	R--	123,344	126,976	6.9680	高（可能已压缩）
.reloc	R--	860	4,096	1.6193	偏低（结构化数据）

导入模块总数	56
其中 API Set 转发	47 个（api-ms-win-* 转发模块，属系统机制）
其中无函数导入	6 个（仅声明依赖，未实际调用）

关键导入模块

模块	函数数	代表性函数
USER32.dll	87	PostQuitMessage, BeginPaint, EndPaint, FillRect, DrawTextW, DrawFocusRect, DefWindowProcW, TrackMouseEvent, InvalidateRect, DestroyIcon
GDI32.dll	25	SetMapMode, SetViewportExtEx, SetWindowExtEx, LPtoDP, SetBkMode, GetTextMetricsW, TextOutW, AbortDoc, EndDoc, SetAbortProc
COMCTL32.dll	11	ImageList_Create, ImageList_SetBkColor, Ordinal_381, ImageList_Replacelcon, Ordinal_410, ImageList_Draw, ImageList_GetIconSize, Ordinal_413, ImageList_Destroy, Ordinal_345

模块	函数数	代表性函数
USER32.dll	87	PostQuitMessage, BeginPaint, EndPaint, FillRect, DrawTextW, DrawFocusRect, DefWindowProcW, TrackMouseEvent
api-ms-win-crt-private-l1-1-0.dll	39	_o__get_wide_winmain_command_line, _o__initialize_onexit_table, _o__initialize_wide_environment, _o__invalid_parameter_noinfo, _o__purecall, _o__register_onexit_function, _o__seh_filter_exe, _o__set_app_type
GDI32.dll	25	SetMapMode, SetViewportExtEx, SetWindowExtEx, LPtoDP, SetBkMode, GetTextMetricsW, TextOutW, AbortDoc
api-ms-win-core-synch-l1-1-0.dll	17	LeaveCriticalSection, InitializeCriticalSectionEx, WaitForSingleObject, ReleaseSemaphore, ReleaseSRWLockExclusive, EnterCriticalSection, SetEvent, CreateEventExW
api-ms-win-core-file-l1-1-0.dll	13	DeleteFileW, GetFileAttributesW, SetEndOfFile, GetFileAttributesExW, GetFileInformationByHandle, FindClose, FindFirstFileW, CreateFileW

模块	函数数	代表性函数
COMCTL32.dll	11	ImageList_Create, ImageList_SetBkColor, Ordinal_381, ImageList_Replacelcon, Ordinal_410, ImageList_Draw, ImageList_GetIconSize, Ordinal_413
api-ms-win-core-libraryloader-l1-2-0.dll	10	LockResource, GetModuleHandleExW, FindResourceExW, LoadResource, GetModuleHandleA, GetModuleFileNameA, FreeLibrary, GetProcAddress
api-ms-win-core-com-l1-1-0.dll	9	CoTaskMemFree, CoCreateInstance, CoInitializeEx, PropVariantClear, CoUninitialize, CoWaitForMultipleHandles, CoCreateGuid, CoTaskMemAlloc
api-ms-win-core-registry-l1-1-0.dll	9	RegQueryInfoKeyW, RegGetValueW, RegOpenKeyExW, RegDeleteKeyExW, RegEnumValueW, RegCloseKey, RegQueryValueExW, RegCreateKeyExW
api-ms-win-core-processthreads-l1-1-0.dll	7	GetCurrentProcess, OpenProcessToken, CreateProcessW, TerminateProcess, GetCurrentThreadId, GetStartupInfoW, GetCurrentProcessId
api-ms-win-core-heap-l2-1-0.dll	7	LocalUnlock, LocalFree, LocalLock, GlobalAlloc, GlobalFree, LocalAlloc, LocalReAlloc
api-ms-win-core-errorhandling-l1-1-0.dll	5	UnhandledExceptionFilter, SetUnhandledExceptionFilter, RaiseException, GetLastError, SetLastError
api-ms-win-crt-runtime-l1-1-0.dll	4	_c_exit, _initterm_e, _initterm, _register_thread_local_exe_atexit_callback
api-ms-win-core-heap-l1-1-0.dll	4	GetProcessHeap, HeapAlloc, HeapSetInformation, HeapFree
api-ms-win-core-threadpool-l1-2-0.dll	4	CloseThreadpoolTimer, WaitForThreadpoolTimerCallbacks, CreateThreadpoolTimer, SetThreadpoolTimer
api-ms-win-core-localization-l1-2-0.dll	4	FormatMessageW, FindNLSString, GetLocaleInfoW, GetACP
api-ms-win-core-winrt-string-l1-1-0.dll	4	WindowsDeleteString, WindowsCreateString, WindowsCreateStringReference, WindowsGetStringRawBuffer
api-ms-win-core-string-l1-1-0.dll	4	FoldStringW, WideCharToMultiByte, CompareStringOrdinal, MultiByteToWideChar
api-ms-win-eventing-provider-l1-1-0.dll	4	EventRegister, EventUnregister, EventWriteTransfer, EventSetInformation
api-ms-win-crt-string-l1-1-0.dll	3	wcscmp, wcsnlen, memset

模块	函数数	代表性函数
api-ms-win-core-debug-l1-1-0.dll	3	IsDebuggerPresent, OutputDebugStringW, DebugBreak
api-ms-win-core-shlwapi-legacy-l1-1-0.dll	3	PathFileExistsW, PathIsFileSpecW, PathFindExtensionW
api-ms-win-core-processenvironment-l1-1-0.dll	3	GetCurrentDirectoryW, GetCommandLineW, SetCurrentDirectoryW
api-ms-win-core-memory-l1-1-0.dll	3	MapViewOfFile, CreateFileMappingW, UnmapViewOfFile
api-ms-win-core-heap-obsolete-l1-1-0.dll	3	LocalSize, GlobalLock, GlobalUnlock
api-ms-win-core-rtlsupport-l1-1-0.dll	3	RtlLookupFunctionEntry, RtlCaptureContext, RtlVirtualUnwind
api-ms-win-core-sysinfo-l1-1-0.dll	2	GetLocalTime, GetSystemTimeAsFileTime
api-ms-win-core-datetime-l1-1-0.dll	2	GetDateFormatW, GetTimeFormatW
api-ms-win-core-processthreads-l1-1-1.dll	2	IsProcessorFeaturePresent, GetProcessMitigationPolicy
api-ms-win-core-handle-l1-1-0.dll	1	CloseHandle
api-ms-win-core-registry-l1-1-1.dll	1	RegSetKeyValueW
api-ms-win-core-largeinteger-l1-1-0.dll	1	MulDiv
api-ms-win-core-winrt-l1-1-0.dll	1	RoGetActivationFactory
api-ms-win-shcore-obsolete-l1-1-0.dll	1	SHStrDupW

模块	函数数	代表性函数
api-ms-win-security-base-l1-1-0.dll	1	GetTokenInformation
api-ms-win-core-psapi-l1-1-0.dll	1	K32GetModuleFileNameExW
api-ms-win-core-localization-obsolete-l1-2-0.dll	1	GetUserDefaultUILanguage
api-ms-win-shcore-path-l1-1-0.dll	1	Ordinal_170
api-ms-win-core-registry-l2-1-0.dll	1	RegCreateKeyW
api-ms-win-shcore-scaling-l1-1-1.dll	1	GetDpiForMonitor
api-ms-win-core-string-obsolete-l1-1-0.dll	1	lstrcmpiW
api-ms-win-core-windowerrorreporting-l1-1-3.dll	1	RegisterApplicationRestart
api-ms-win-base-util-l1-1-0.dll	1	IsTextUnicode
api-ms-win-core-libraryloader-l1-2-1.dll	1	FindResourceW
api-ms-win-core-profile-l1-1-0.dll	1	QueryPerformanceCounter
api-ms-win-core-interlocked-l1-1-0.dll	1	InitializeSListHead
api-ms-win-core-winrt-error-l1-1-0.dll	1	SetRestrictedErrorInfo
api-ms-win-core-winrt-error-l1-1-1.dll	1	RoGetMatchingRestrictedErrorInfo

模块	函数数	代表性函数
api-ms-win-core-delayload-l1-1-1.dll	1	ResolveDelayLoadedAPI
api-ms-win-core-delayload-l1-1-0.dll	1	DelayLoadFailureHook
ADVAPI32.dll	0	
COMDLG32.dll	0	
PROPSYS.dll	0	
SHELL32.dll	0	
WINSPOOL.DRV	0	
urlmon.dll	0	

5. 运行期观测

采集覆盖状态

观测维度	状态	数据量	说明
动态会话	未执行	0	测试 Profile 未包含动态任务，或目标未启动
进程活动	无记录	0 条	未观测到进程创建
文件系统	无记录	0 条	目标未改动文件，或监控权限不足
注册表	无记录	0 条	目标未改动注册表，或监控权限不足
网络连接	无记录	0 条	未采集到连接记录（标准用户下无抓包能力）

「未采集」表示该维度没有数据，**不代表该维度没有问题** —— 请对照说明确认是目标行为如此，还是采集能力受限/工具缺失。

本次为纯静态分析，未产生任何运行期数据。如需观测运行行为，请在「测试执行」页面选择包含动态任务的 Profile 后重跑。

6. 依赖分析

未解析到依赖项。

7. 安全发现

WS-101

中危

可执行文件缺少有效的数字签名

规则	WS-001（代码完整性与签名）
置信度	高
状态	待确认
命中对象	C:\Users\TianManyi\WorkBuddy\winseclab\wsx-smoke\Projects\WS-20261006-014_全工具链路验证\Target\target.exe
CWE	CWE-345
OWASP	A08:2021 Software and Data Integrity Failures
P	
来源	WinSecLab 规则引擎

说明

被测主程序未通过 WinVerifyTrust 校验。缺失或无效的签名意味着二进制内容无法与发布者身份绑定，同时也会让终端防护软件降低对它的信任评级。

命中事实：

- 签名状态：未签名
- WinVerifyTrust 返回：0x800B0100

影响

无法验证发布者与完整性：分发链被替换、被第三方二次打包时不会有任何提示。

复现步骤

1. 在隔离的 Windows 测试环境中以测试账号运行被测程序（本次会话已记录证据）。
2. 关注对象：C:\Users\TianManyi\WorkBuddy\winseclab\wsx-smoke\Projects\WS-20261006-014_全工具链路验证\Target\target.exe
3. 在 WS-001 关联的证据条目中查看原始记录（进程 / 文件 / 注册表 / 网络时间线）。
4. 若需精确归因（谁写的、哪个线程调的），按建议启用 Process Monitor 适配器复现一次。

整改建议

为发布版本配置代码签名证书（EV 证书可获得 SmartScreen 立即信誉），在 CI 中对每个产物签名并校验。

关联证据

证据 ID	类型	标题	来源
EV-TOOL-00009	ToolOutput	签名交叉验证 (Sigcheck)	sigcheck
EV-SIGN-00008	Signature	数字签名校验结果	builtin.signature

关联实体

- 文件: C:\Users\TianManyi\WorkBuddy\winseclab\wsx-smoke\Projects\WS-20261006-014_全工具链路验证\Target\target.exe

规则	WS-014（防篡改与构建可信性）
置信度	高
状态	待确认
命中对象	C:\Users\TianManyi\WorkBuddy\winseclab\wsx-smoke\Projects\WS-20261006-014_全工具链路验证\Target\target.exe
CWE	CWE-200
OWASP	A05:2021 Security Misconfiguration
来源	WinSecLab 规则引擎

说明

PE 的调试目录中保留了 CodeView 记录，包含编译机上的 PDB 路径。这属于信息泄露：可能暴露项目结构和开发者账号名；同时也说明这是未做符号剥离的调试或内部版本。

命中事实：

- 调试路径：notepad.pdb

影响

泄露内部目录结构与可能的开发者身份信息，便于攻击者构造针对性攻击。

复现步骤

1. 在隔离的 Windows 测试环境中以测试账号运行被测程序（本次会话已记录证据）。
2. 关注对象：C:\Users\TianManyi\WorkBuddy\winseclab\wsx-smoke\Projects\WS-20261006-014_全工具链路验证\Target\target.exe
3. 在 WS-014 关联的证据条目中查看原始记录（进程 / 文件 / 注册表 / 网络时间线）。
4. 若需精确归因（谁写的、哪个线程调的），按建议启用 Process Monitor 适配器复现一次。

整改建议

发布构建中使用 /DEBUG:NONE，或构建后剥离调试目录与 PDB 引用。

关联证据

证据 ID	类型	标题	来源
EV-PE-00004	Pe	资源目录摘要	builtin.pe
EV-PE-00003	Pe	Rich Header / 编译器指纹	builtin.pe

证据 ID	类型	标题	来源
EV-PE-00002	Pe	调试目录 (PDB 路径)	builtin.pe
EV-PE-00001	Pe	PE 结构画像	builtin.pe

关联实体

- 文件: C:\Users\TianManyi\WorkBuddy\winseclab\wsx-smoke\Projects\WS-20261006-014_全工具链路验证\Target\target.exe

规则	WS-302（工具链与环境）
置信度	高
状态	待确认
命中对象	本机测试环境
CWE	CWE-1059
来源	WinSecLab 规则引擎

说明

本次分析未能以管理员权限运行，或所需的第三方工具未安装。进程事件退化为轮询、注册表事件精度受扫描间隔限制、TLS 证书字段无法解析等，都会让证据出现空白。

命中事实：

- 当前未以管理员权限运行

影响

证据缺失可能掩盖真实存在的问题，结论只能作为「已知范围内」的判断。

复现步骤

1. 在隔离的 Windows 测试环境中以测试账号运行被测程序（本次会话已记录证据）。
2. 关注对象：本机测试环境
3. 在 WS-302 关联的证据条目中查看原始记录（进程 / 文件 / 注册表 / 网络时间线）。
4. 若需精确归因（谁写的、哪个线程调的），按建议启用 Process Monitor 适配器复现一次。

整改建议

以管理员身份重新运行一次完整测试；按「插件与工具」页面的提示安装 Process Monitor、Wireshark（含 tshark）、YARA、Ghidra 等工具后复测，获得内核级精确归因。

共 23 条证据，全部落盘在项目目录下，可通过证据 ID 在数据库中检索原始记录。

证据 ID	类型	标题	来源	时间
EV-TOOL-00023	ToolOutput	x64dbg 调试工作流已就绪	x64dbg	2026-10-06 09:53:43.051
EV-TOOL-00022	ToolOutput	Ghidra 工作流已就绪	ghidra	2026-10-06 09:53:43.039
EV-STAT-00021	Static	发现项汇总	builtin.correlation	2026-10-06 09:53:43.019
EV-STAT-00020	Static	关联分析汇总	builtin.correlation	2026-10-06 09:53:43.017
EV-TOOL-00019	ToolOutput	外部 YARA 引擎结果	yara	2026-10-06 09:53:42.960
EV-TOOL-00018	ToolOutput	内置提取器遗漏的关注字符串	strings	2026-10-06 09:53:42.770
EV-TOOL-00017	ToolOutput	字符串提取召回率对照	strings	2026-10-06 09:53:42.767
EV-STRI-00016	Strings	字符串：Format (7 条)	builtin.strings	2026-10-06 09:53:42.578
EV-STRI-00015	Strings	字符串：文件路径 (61 条)	builtin.strings	2026-10-06 09:53:42.578
EV-STRI-00014	Strings	字符串提取总览 (944 条)	builtin.strings	2026-10-06 09:53:42.573
EV-STRI-00013	Strings	字符串：IP 地址 (2 条)	builtin.strings	2026-10-06 09:53:42.571
EV-STRI-00012	Strings	字符串：URL 地址 (3 条)	builtin.strings	2026-10-06 09:53:42.571
EV-STRI-00011	Strings	字符串：安全相关 API 名 (3 条)	builtin.strings	2026-10-06 09:53:42.570
EV-ENTR-00010	Entropy	熵值分析	builtin.entropy	2026-10-06 09:53:42.455
EV-TOOL-00009	ToolOutput	签名交叉验证 (Sigcheck)	sigcheck	2026-10-06 09:53:42.449

证据 ID	类型	标题	来源	时间
EV-SIGN-00008	Signature	数字签名校验结果	builtin.signature	2026-10-06 09:53:42.167
EV-TOOL-00007	ToolOutput	导入表交叉验证 (Dependencies.exe)	dependencies	2026-10-06 09:53:42.157
EV-DEPE-00006	Dependenc y	同目录二进制清单	builtin.dependencie s	2026-10-06 09:53:41.903
EV-DEPE-00005	Dependenc y	依赖解析结果	builtin.dependencie s	2026-10-06 09:53:41.901
EV-PE-00004	Pe	资源目录摘要	builtin.pe	2026-10-06 09:53:41.673
EV-PE-00003	Pe	Rich Header / 编译器指纹	builtin.pe	2026-10-06 09:53:41.671
EV-PE-00002	Pe	调试目录 (PDB 路径)	builtin.pe	2026-10-06 09:53:41.668
EV-PE-00001	Pe	PE 结构画像	builtin.pe	2026-10-06 09:53:41.667

9. 风险整改

按严重级与整改成本排序，建议按以下顺序推进。优先级 P0 应立即处理，P1 在下一个迭代修复，P2 纳入技术债跟踪，P3 视情况优化。

优先级	编号	问题	建议动作	验证方式
P1 下个迭代	WS-101	可执行文件缺少有效的数字签名	为发布版本配置代码签名证书（EV 证书可获得 SmartScreen 立即信誉），在 CI 中对每个产物签名并校验。	用 signtool verify /pa /v 校验产物签名与时间戳
P3 可选	WS-102	二进制保留了调试信息（PDB 路径）	发布构建中使用 /DEBUG:NONE，或构建后剥离调试目录与 PDB 引用。	按整改建议复测一次，保留前后证据对比
P3 可选	WS-103	测试环境权限不足，部分证据的完整性受限	以管理员身份重新运行一次完整测试；按「插件与工具」页面的提示安装 Process Monitor、Wireshark（含 tshark）、YARA、Ghidra 等工具后复测，获得内核级精确归因。	按整改建议复测一次，保留前后证据对比

10. 附录

10.1 分析产物

- Target/ —— 被测文件与依赖副本
- Static Analysis/ —— PE 画像、字符串、依赖、.NET 元数据
- Dynamic Analysis/ —— 事件流 (JSONL) 与进程树
- Network/ —— 连接表、DNS、HTTP 历史
- Findings/ —— 统一发现 (JSON)
- Reports/ —— 本报告
- analysis.db —— SQLite 证据库 (可用任意 SQLite 客户端查询)

10.4 报告局限与免责说明

本报告的所有结论均基于 WinSecLab 在本次会话中实际采集到的证据。以下因素会影响结论的完整性：

- 内置文件与注册表监控采用「路径相关性 + 时间窗」归因，无法像内核级监控那样把每个事件精确绑定到发起线程；需要精确性时请启用 Process Monitor 适配器复现。
- 未安装的第三方工具 (Wireshark / YARA / Ghidra 等) 对应的分析维度为空白，不代表该维度没有问题。
- HTTPS 流量未做中间人解密，仅记录 CONNECT 目标主机，无法审计加密后的请求内容。
- 自动发现只负责提示；所有中高危结论都应经人工复核证据后确认。

测试对象应为本人拥有或已明确获得书面授权测试的 Windows 应用与测试环境。

10.5 安全关系图 (Security Graph)

中心为被测程序，向外依次为模块 / 网络 / 进程 / 文件 / 注册表 / 发现。红色节点表示可疑。

WS-101 可执行文件缺少有效的数字签名

target.exe

